ESEN

CIBERSEGURIDAD

Informe ejecutivo del análisis de impacto

El documento que la dirección lee, discute y firma

Ejemplo resuelto de cátedra · Nexo Crítico Consultores · Energía Nacional S.A. de C.V. (ENSA)

Análisis de Impacto en el Negocio · Plantilla 07 de 07

ISO 22301:2019 · ISO/TS 22317:2021 · NIST SP 800-34 Rev. 1

Docente: Ing. Héctor Cuchilla

ESEN – CIBERSEGURIDAD – CICLO 03 – 2026

Tabla de contenidos

1. Identificación del trabajo..... 3
2. Resumen ejecutivo..... 3
3. Alcance y método..... 4
4. Procesos críticos priorizados y sus métricas de tiempo..... 5
5. Costo de la indisponibilidad..... 5
6. Puntos únicos de falla y brechas que exigen decisión..... 6
7. Frontera con el análisis de riesgos..... 6
8. Justificación económica del control, en cinco pasos..... 7
9. Costo anual del control (ACC)..... 7
10. Retorno de la inversión en seguridad (ROSI)..... 8
11. Análisis de sensibilidad en tres escenarios..... 8
12. Recomendaciones y decisión solicitada a la dirección..... 9
13. Aprobación..... 10
14. Referencias..... 10

Ejemplo resuelto de cátedra · anexo 7 de 7. Es el documento que la dirección de ENSA lee, discute y firma.

1. Identificación del trabajo

Esta plantilla se llena por equipo y sobre la empresa que el equipo tiene asignada en el catálogo del Proyecto Final. El caso resuelto que la Guía del Estudiante desarrolla usa la Red Hospitalaria Metropolitana; cada equipo aplica el mismo método a su propia empresa.

Campo	Contenido
Empresa del catálogo del Proyecto Final	Energía Nacional S.A. de C.V. (ENSA), perfil n.° 4
Sector y tamaño declarados en el perfil	Energía y servicios públicos · mediana, 550 empleados
Equipo (número y nombre)	Equipo 04 · Nexo Crítico Consultores
Integrantes	Seis integrantes con los cinco roles cubiertos
Analista responsable de esta plantilla	Alejandra Beltrán Rivas, consultora líder
Fecha de elaboración	15 de octubre de 2026
Versión del documento	v1.1 · viernes 23 de octubre de 2026, con las secciones 8 a 11 entregadas junto con E.05

2. Resumen ejecutivo

Una página como máximo, escrita para la dirección. Contiene la exposición de la organización expresada en dinero por unidad de tiempo, el plazo de tolerancia que el propio negocio declaró, los hallazgos que exigen decisión y la recomendación con su costo.

El análisis de impacto evaluó diez procesos de ENSA y confirmó dos como críticos: la operación de la red de control (SCADA/OT) y la gestión de interrupciones (OMS). El sistema comercial y de facturación y la medición inteligente (AMI), que el perfil declara críticos, resultaron importantes con 2,46: a las veinticuatro horas ninguna de sus calificaciones pasa de 3 y su impacto crece en días. La distancia entre el telecontrol y los procesos comerciales es la conclusión que gobierna las decisiones: el telecontrol tolera cuatro horas de interrupción, mientras que la facturación tolera setenta y dos. Cada hora sin telecontrol cuesta USD 62 000 en el escenario de temporada de lluvias, y al alcanzar el período máximo tolerable la pérdida asciende a USD 248 000.

El análisis identificó ocho puntos únicos de falla y ocho brechas. Cuatro exigen decisión inmediata: el respaldo del sistema SCADA no permite cumplir los objetivos de recuperación declarados; los puntos de conexión entre la red de TI y la red OT no atraviesan un filtro documentado, tal como el propio perfil reconoce al describir un aislamiento que no es real; el acceso remoto del proveedor del sistema de control opera sin autenticación multifactor ni registro; y no existe inventario ni monitoreo de seguridad en la red OT.

El tratamiento del riesgo de mayor exposición —compromiso del entorno SCADA por propagación desde la red de TI — se justifica económicamente con holgura: la pérdida anual esperada asciende a USD 2 475 000 y el conjunto de controles propuesto la reduce a USD 990 000 con un costo anual de USD 186 000, lo que produce un retorno de 698 %. La recomendación se mantiene en los tres escenarios de sensibilidad, incluido el más conservador.

3. Alcance y método

Campo	Contenido
Procesos incluidos en el análisis	Los diez procesos del censo de BIA_P01: los cuatro que el perfil declara críticos y seis de soporte con efecto directo sobre ellos
Procesos excluidos y por qué	Red inalámbrica de invitados, videovigilancia de subestaciones y equipos de medición en poder del cliente, con la justificación declarada en E.02; la videovigilancia se registra como brecha B-07 por su convergencia no resuelta con la red OT
Período de levantamiento	Del 29 de septiembre al 14 de octubre de 2026
Medios de levantamiento empleados	Entrevista estructurada con los cinco dueños de proceso, cuestionario estandarizado, taller con áreas interdependientes, revisión documental de contratos y bitácoras, validación firmada y aprobación de la dirección
Personas entrevistadas y áreas participantes	Gerencia General, Operaciones de Red, Técnica, Comercial, Finanzas y TI/TO; dos operadores del centro de control y un ingeniero de subestaciones
Método de valoración empleado	Cuantitativo para las categorías financiera y operativa, cualitativo para la reputacional y la de seguridad de las personas, y semicuantitativo en la priorización ponderada
Escenario temporal usado (período pico considerado)	Temporada de lluvias y tormentas eléctricas, de mayo a octubre, con factor de agravamiento de 2,2 × en fallas simultáneas y 1,6 × en costo por hora

4. Procesos críticos priorizados y sus métricas de tiempo

Orden	Proceso	Clase	MTPD	RTO	WRT	RPO	MBCO declarado
1	P-01 Operación de la Red de Control (SCADA/OT)	Crítico	4 h	2 h	1,5 h	15 min	Operación manual de las doce subestaciones principales con radio troncalizado
2	P-03 Sistema de Gestión de Interrupciones (OMS)	Crítico	8 h	4 h	3 h	1 h	Despacho de cuadrillas con planillas impresas y avisos por el centro de contacto
3	P-09 Gestión de TI corporativa	Importante	24 h	8 h	4 h	4 h	Autenticación local de emergencia y correo en modo básico
4	P-06 Gestión de campo y cuadrillas con GIS	Importante	48 h	24 h	8 h	8 h	Órdenes de trabajo en planilla impresa con despacho por radio
5	P-04 Sistema Comercial y de Facturación	Importante	72 h	24 h	24 h	4 h	Facturación con lectura estimada del ciclo anterior para el 100 % de los clientes regulados
6	P-02 Gestión de Medición Inteligente (AMI)	Importante	48 h	24 h	12 h	6 h	Lectura manual del 15 % de clientes de mayor consumo y estimación para el resto

Comprobación de coherencia de todas las fichas: RTO + WRT ≤ MTPD. Fichas que la superan: _____ de _____.

En los seis procesos se cumple la comprobación RTO + WRT ≤ MTPD. El margen más estrecho es el del proceso de control de red: media hora sobre cuatro.

5. Costo de la indisponibilidad

Proceso	Costo por hora	Costo por día	Costo al alcanzar el MTPD	Supuesto principal
P-01 Operación de la Red de Control (SCADA/OT)	USD 62 000	USD 1 488 000	USD 248 000 (4 h)	Derivación de la ficha: ingresos no percibidos de USD 38 000 por hora (190 MW × USD 200 por MWh)
P-03 Sistema de Gestión de Interrupciones (OMS)	USD 18 500	USD 444 000	USD 148 000 (8 h)	Penalización por tiempo de restauración e improductividad de cuadrillas
P-04 Sistema Comercial y de Facturación (importante)	USD 7 400	USD 177 600	USD 532 800 (72 h)	Facturación diferida del ciclo, recuperable con cobro posterior

Proceso	Costo por hora	Costo por día	Costo al alcanzar el MTPD	Supuesto principal
P-02 Gestión de Medición Inteligente (AMI) (importante)	USD 2 900	USD 69 600	USD 139 200 (48 h)	Lectura manual y estimación del consumo del ciclo

El MTPD se expresa en horas transcurridas y el costo acumula solo durante la ventana de operación del proceso.

El costo por hora del proceso de control de red es 8,4 veces el del sistema comercial; el costo al alcanzar el período máximo tolerable, en cambio, es mayor en el sistema comercial, porque su MTPD es dieciocho veces más largo. La dirección decide sobre las dos cifras: la primera ordena la urgencia de la recuperación y la segunda, la magnitud del daño acumulado.

6. Puntos únicos de falla y brechas que exigen decisión

Hallazgo	Proceso afectado	Consecuencia	Acción propuesta	Costo estimado
SPOF-08 / B-01 · Respaldo semanal en cinta, sin copia aislada ni prueba de restauración	P-01, P-03	Recuperación fuera del RPO de 15 minutos y del RTO de 2 horas	Respaldo diario con copia aislada e inmutable y prueba de restauración trimestral	USD 74 000 anuales
B-02 · Puntos de conexión TI–OT sin filtro documentado	P-01, P-03	Propagación directa de un incidente de TI al entorno de control	Segmentación con zona intermedia, reglas aprobadas y revisión trimestral	USD 118 000 anuales
SPOF-04 / B-05 · Acceso remoto del proveedor sin multifactor ni registro	P-01	Entrada directa al entorno de control desde fuera de la organización	Concentrador de acceso con multifactor, aprobación por sesión y grabación	USD 96 000 anuales
B-03 / B-04 · Sin inventario ni monitoreo de la red OT	P-01, P-02	Intrusión indetectable e imposibilidad de investigar	Inventario con descubrimiento pasivo y sonda de detección en OT	USD 68 000 anuales
SPOF-01 / B-08 · Un solo ingeniero con competencia de administración del SCADA	P-01, P-03	Recuperación dependiente de una persona y del soporte del fabricante	Documentación de la configuración, formación de un segundo ingeniero y contrato de respuesta en 4 horas	USD 32 000 anuales
SPOF-02 · Centro de control sin redundancia ni puesto de mando equipado	P-01, P-03	Pérdida total del telecontrol si la sala queda indisponible	Equipar el puesto de mando móvil con dos estaciones y enlace de radio	USD 45 000, inversión única

7. Frontera con el análisis de riesgos

Lo que este informe entrega como resultado del BIA: la lista priorizada de procesos, los objetivos de tiempo, el costo de la interrupción por unidad de tiempo, y el valor del activo con su factor de exposición, de donde sale la pérdida esperada por evento único.

Lo que corresponde al análisis de riesgos: la tasa anualizada de ocurrencia (ARO) y la pérdida anual esperada (ALE = SLE × ARO), conforme a NIST SP 800-30 Rev. 1, porque ambas requieren estimar la probabilidad de la amenaza. El BIA responde qué pasa si ocurre; el análisis de riesgos responde con qué frecuencia ocurrirá.

El análisis de impacto entrega el valor del proceso, el factor de exposición y la pérdida por evento único. La frecuencia con que ese evento ocurre no es una pregunta del análisis de impacto: depende de la amenaza, de la exposición y de los controles existentes, y se estima en la matriz de riesgos del entregable E.05. Allí se calcula la tasa anualizada de ocurrencia, la pérdida anual esperada y el retorno de cada control, con los valores de pérdida por evento único que este informe entrega: USD 4 950 000 para el proceso de control de red, USD 1 300 000 para la gestión de interrupciones, USD 1 395 000 para el sistema comercial y USD 480 000 para la medición inteligente, dos procesos importantes que conservan su valoración, y USD 105 000 por la exposición de los datos personales de los clientes en P-04 y en P-05.

8. Justificación económica del control, en cinco pasos

En el Proyecto Final, las secciones 8 a 11 se marcan «se completa en E.05» en la entrega del hito H2 y se completan en la versión 1.1 de este informe, que se entrega junto con E.05.

Paso	Resultado	Cómo se obtuvo y con qué fundamento
1. ALE actual, sin control adicional (línea base de riesgo)	USD 2 475 000	SLE de USD 4 950 000 (BIA_P02, sección 9) por una tasa anualizada de ocurrencia de 0,5, que corresponde al nivel 4 de probabilidad de la escala de E.05
2. Efectividad estimada del control (sobre el SLE o sobre el ARO)	Reducción de la tasa de 0,5 a 0,2	La segmentación con zona intermedia elimina la propagación directa desde la red de TI y la detección pasiva reduce el tiempo de permanencia del atacante: dos niveles menos de probabilidad en la escala declarada
3. ALE con el control operando	USD 990 000	SLE de USD 4 950 000 por la tasa de 0,2
4. Beneficio (diferencia entre ambos ALE)	USD 1 485 000	2 475 000 − 990 000
5. Costos totales del control (ACC)	USD 186 000 anuales	Suma de las tres familias de gasto de la sección 9

La efectividad se apoya en especificaciones técnicas y estudios, no en la impresión del proveedor.

9. Costo anual del control (ACC)

Omitir cualquiera de las tres familias de gasto infla el retorno aparente y produce decisiones que el presupuesto desmiente al año siguiente.

Familia de gasto	Componentes que incluye	Monto anual
Adquisición	Dos cortafuegos industriales para la zona intermedia y una sonda de detección pasiva para la red OT, con implantación; inversión de USD 480 000 anualizada sobre cinco años de vida útil	USD 96 000
Operación	Media plaza de analista de seguridad de tecnología de operación, revisión trimestral de reglas y atención de alertas	USD 62 000
Mantenimiento	Soporte y actualizaciones del fabricante, afinamiento de firmas y capacitación del personal de operación	USD 28 000
Total ACC		**USD 186 000**

10. Retorno de la inversión en seguridad (ROSI)

ROSI = (Beneficio − ACC) ÷ ACC, expresado en porcentaje.

Beneficio: _____ − ACC: _____ = Beneficio neto: _____

Beneficio neto ÷ ACC = ROSI: _____ %

El indicador permite comparar controles entre sí y ordenar el gasto, y su valor depende por completo de la calidad de las estimaciones que lo alimentan.

ROSI = (Beneficio − ACC) ÷ ACC = (1 485 000 − 186 000) ÷ 186 000 = **698 %**. El control se justifica porque su costo anual equivale al 12,5 % de la reducción de pérdida esperada que produce, y porque el costo de una sola hora de indisponibilidad del telecontrol, USD 62 000, cubre un tercio del costo anual del control.

11. Análisis de sensibilidad en tres escenarios

Escenario	ARO	ALE	Beneficio	ACC	ROSI	La recomendación se mantiene
Mínimo	0,2	USD 990 000	USD 594 000	USD 186 000	219 %	Sí
Esperado	0,5	USD 2 475 000	USD 1 485 000	USD 186 000	698 %	Sí
Máximo	1,0	USD 4 950 000	USD 2 970 000	USD 186 000	1 497 %	Sí

Conclusión sobre la robustez de la recomendación. Si cambia de signo al variar un solo supuesto, decirlo con esas palabras y nombrar el supuesto del que depende:

La conclusión es robusta: el control se justifica incluso con la frecuencia más baja del rango y con el factor de exposición mínimo del supuesto S-12. La variable que sí exige validación de la dirección es otra: la duración máxima sostenible del procedimiento alterno (dato de la ficha: 12 horas con un solo relevo, en un rango de 8 a 16), porque si el valor real se acerca a las ocho horas del simulacro, el período máximo tolerable de cuatro horas debe revisarse a la baja y el objetivo de recuperación se vuelve más exigente.

12. Recomendaciones y decisión solicitada a la dirección

N.°	Recomendación	Proceso o hallazgo que la origina	Costo	Decisión solicitada
1	Implantar el respaldo diario del entorno SCADA con copia aislada e inmutable y prueba de restauración trimestral	B-01 / SPOF-08	USD 74 000 anuales	Aprobar e iniciar en el primer trimestre
2	Segmentar los puntos de conexión entre la red de TI y la red OT con zona intermedia y reglas aprobadas	B-02	USD 118 000 anuales	Aprobar e iniciar en el primer trimestre
3	Someter el acceso remoto de proveedores a multifactor, cuenta nominal y grabación de sesión	B-05 / SPOF-04	USD 96 000 anuales	Aprobar y renegociar el contrato de soporte
4	Inventariar los activos de la red OT con descubrimiento pasivo y desplegar detección de intrusiones en OT	B-03 / B-04	USD 68 000 anuales	Aprobar para el segundo semestre
5	Documentar la configuración del SCADA, formar un segundo ingeniero y contratar respuesta del fabricante en 4 horas	SPOF-01 / B-08	USD 32 000 anuales	Aprobar e iniciar de inmediato, por su bajo costo
6	Equipar el puesto de mando móvil como centro de control alterno	SPOF-02	USD 45 000, inversión única	Decidir en la revisión trimestral
7	Validar con la Gerencia de Operaciones de Red la duración máxima sostenible del procedimiento alterno y, si procede, revisar el MTPD	Ficha de datos del cliente, procedimiento alterno del SCADA	Sin costo directo	Instruir la validación antes del cierre del ejercicio

13. Aprobación

Rol	Nombre y cargo	Fecha	Firma
Analista responsable del BIA	Alejandra Beltrán Rivas, consultora líder · Nexo Crítico Consultores	15 de octubre de 2026	(firma)
Responsable de seguridad de la información	Ing. Karla Beatriz Vásquez, Jefa de Seguridad de la Información	15 de octubre de 2026	(firma)
Dirección general	Ing. Óscar Mauricio Handal, Gerente General	16 de octubre de 2026	(firma)

14. Referencias

- ISO 22301:2019 — Seguridad y resiliencia. Sistemas de gestión de la continuidad del negocio. Requisitos.
- ISO/TS 22317:2021 — Directrices para el análisis de impacto en el negocio. Segunda edición, confirmada vigente en 2025.
- NIST SP 800-34 Rev. 1 — Guía de planificación de contingencia para sistemas de información federales.
- NIST SP 800-30 Rev. 1 — Guía para la conducción de evaluaciones de riesgo.
- NIST CSF 2.0 (2024) — Marco de ciberseguridad, funciones de gobernar, identificar y recuperar.
- CIS Controls v8.1 (2024) — Controles de inventario de activos y de recuperación de datos.
- The Open Group — Risk Taxonomy (O-RT) versión 3.0.1 y Risk Analysis (O-RA) versión 2.0.1, noviembre de 2021.